

Fase 3: Implementación de Controles - OmniSalud

Metodología ISO 31000, ISO 27701 y Estándar de Auditoría IA (AEPD)

Unidad de Negocio: OmniSalud
Responsable: Gonzalo Vega Batyi, Abogado / DPO
Referencia: Hallazgo de 404 perfiles con datos sensibles comprometidos.

1. Selección y Diseño de Controles (ISO 31000: 6.5.1)

Basado en el análisis de riesgos, se implementarán controles compensatorios para mitigar el riesgo extremo identificado. Los controles se alinean con el Sistema de Gestión de Privacidad de la Información (SGPI) bajo ISO 27701.

1.1 Controles Propuestos

ID Control	Descripción	Estándar Referenciado	Responsable
C.01	Implementar segregación lógica de datos: Crear roles de acceso diferenciados (clínico vs. no clínico) con autenticación multifactor.	ISO 27701:7.4.1 (Control de Acceso)	Equipo de TI del Holding
C.02	Establecer protocolos de actualización de datos: Auditorías trimestrales para verificar exactitud de "Patología_Cronica" y diagnósticos.	Ley 21.719 (Principio de Exactitud)	DPO y Administrador de Unidad
C.03	Desarrollar registro de auditoría (logs): Monitoreo continuo de accesos a la base de datos, con alertas automáticas para accesos no autorizados.	Ley 21.663 (Medidas de Seguridad Organizativas)	Equipo de Ciberseguridad
C.04	Firewall de datos: Implementar barreras lógicas entre OmniSalud y OmniRetail para prevenir "purpose creep".	ISO 31000:6.5.2 (Mejora de Controles)	Arquitecto de Infraestructura

2. Manual de Procedimientos para el Administrador de Unidad

2.1 Procedimiento de Acceso a Datos Sensibles

- Solicitud de Acceso:** El personal debe justificar la necesidad de acceso mediante formulario aprobado por el DPO.
- Verificación de Rol:** Solo usuarios con rol clínico pueden visualizar campos sensibles (e.g., "Patología_Cronica").
- Auditoría Post-Acceso:** Logs se revisan mensualmente; violaciones generan reporte inmediato al DPO.

2.2 Procedimiento de Actualización de Datos

1. **Recolección:** Pacientes actualizan datos vía portal seguro cada 6 meses.
 2. **Validación:** Administrador verifica contra registros médicos; discrepancias se resuelven en 48 horas.
 3. **Notificación:** Afectados son informados de cambios bajo el derecho de rectificación (Ley 21.719).
-

3. Evaluación de Eficacia de Controles (ISO 31000: 6.5.3)

- **Monitoreo Continuo:** KPIs mensuales: 0 accesos no autorizados, 100% actualización de datos en plazo.
 - **Pruebas de Penetración:** Auditorías externas semestrales para validar firewalls de datos.
 - **Revisión Anual:** Ajustes basados en incidentes reportados.
-

4. Conclusión de la Fase 3

La implementación de estos controles reduce el riesgo inherente de EXTREMO a BAJO, permitiendo la continuidad del tratamiento de datos. La inversión estimada es de 2.000.000 CLP en herramientas de TI y capacitación.

Siguiente Etapa: Fase 4: Monitoreo y Revisión Continua (ISO 31000: 6.6).